

Microsoft Support Case Reference: 2605180030003212

# Investigation Report

**Prepared for:**

Genting Plantations Berhad

**Prepared by:**

Ankush Sharma

20/05/2026



# Table of Contents

- EXECUTIVE SUMMARY .....4
- INVESTIGATION OVERVIEW .....5
- ERIKA.JESHAM@GENTINGPLANTATIONS.COM .....6
  - 1- INITIAL SIGN-IN (HOW IT STARTED) ..... 6
    - Session created .....6
    - Malicious IP.....7
    - Conditional access .....10
  - 2- ACTIVITIES PERFORMED BY THREAT ACTOR (START → END) ..... 11
  - 3- REMEDIATION ACTIVITIES (WHEN IT STOPPED) ..... 17
- RECOMMENDATIONS..... 18
  - IDENTITY & ACCESS..... 18
  - MONITORING & DETECTION ..... 19
- APPENDIX ..... 20
  - AITM (ADVERSARY-IN-THE-MIDDLE) QUICK EXPLAINER ..... 20

*Please note that in the report presented, some URLs and IPs may have been modified to include '[.]' (instead of '.'), which is to avoid the chance of any accidental navigation to the URL/IP. All times mentioned are in UTC unless otherwise stated.*

*Details provided in this report are compiled from the discussions conducted and logs provided.*

# Executive Summary

The Microsoft Support Cybersecurity Incident Response Team (CIRT) was engaged on 18<sup>th</sup> of May 2026 to assist with reviewing the Azure and M365 activities for the user account with UPN "**erika.jesham@gentingplantations.com**", which was reported as compromised. The indicators of compromise for the account included unexpected emails sent externally from the user's mailbox and sign-ins from unexpected locations.

CIRT requested M365 Unified Audit logs for the user involved and access to advanced diagnostic data for the tenant (b3a10deb-b783-4098-b047-656b2a9d1453) was provided when the case was raised.

This investigation identified a compromised user session that was abused by a threat actor to access Microsoft 365 workloads. Correlation between Microsoft Entra ID Sign-in Logs and Unified Audit Logs (UAL) confirms that the same session ID was first established during a suspicious sign-in and later reused to perform multiple activities across workloads.

The attack pattern is consistent with a **session hijack**/Adversary-in-the-Middle (AiTM) scenario, where authentication was successfully completed and the attacker leveraged the issued session token to bypass further MFA challenges which allowed the attacker to access the user mailbox and perform actions such as creating inbox rules, accessing mail items etc.

The timeframe of unexpected user activities was observed between <11/05/2026> and <14/05/2026>.

Recommendations have been provided to assist with strengthening your security posture against these types of attacks along with appropriate articles from Microsoft that discuss the AiTM scenario in more detail.

# Investigation Overview

Within the scope of our investigation, we will help you analyze account/tenant/subscription information, based on the currently available logs. The type of logs to analyze and the history depends on the licensing you have for it. Frequently, we can ascertain with a high degree of confidence that an account/tenant/subscription was compromised (and sometimes how and when), depending on the information obtained. However, we cannot make any speculation in case we are not able to double-check any of the IoC you provided because of a lack of logs (e.g. if the log retention period of interest has elapsed).

The following details of the events observed were provided and form the scope for this investigation:

- **Tenant ID:** b3a10deb-b783-4098-b047-656b2a9d1453
- **Affected account:** erika.jesham@gentingplantations.com
- **Role of affected account:** no admin privileged roles
- **Timeframe associated with the events:**
  - Unexpected activity reported on 11<sup>th</sup> of May 2026
  - Mitigation actions on 14<sup>th</sup> of May 2026

The below data was collected/reviewed:

- Unified Audit Logs for the affected user between 10<sup>th</sup> of May 2026 and 17<sup>th</sup> of May 2026
- EntraID Sign in logs (30d tenant retention limit)
- EntraID Audit logs (30d tenant retention limit)
- User and tenant configuration

User Erika.Jesham@gentiplantations.com

## 1- Initial Sign-in (How it started)

The earliest malicious sign-in represents the point at which the threat actor successfully captured and reused the user's authentication token through an Adversary-in-the-Middle (AiTM) or similar phishing attack.

Our investigation identified a successful interactive sign-in to the user account **erika.jesham@gentingplantations.com** originating from an IP address **(104.234.53.4)** in **New York City (US)**. This authentication represents the **first confirmed access event** associated with the subsequent suspicious activity observed in the tenant.

Although **multi-factor authentication (MFA)** was required by Conditional Access policy, no new MFA challenge was performed at the time of this sign-in. Instead, access was granted because the MFA requirement was satisfied by claims already present in the authentication token. The session was established from an **unmanaged and non-compliant device** and was later used to access multiple Microsoft 365 services.

### Session created

- A sign-in event was observed **with session ID 00406c4a-89b6-fabe-2e75-4d7bdf8fd7c1**.
- This session ID later appeared **unchanged** across multiple events, confirming session reuse.
- The authentication was completed successfully, allowing the session to be issued.

### Impact:

Once the session was created, the token could be reused without additional interactive authentication.

**"appDisplayName": "OfficeHome",**  
**"resourceDisplayName": "OfficeHome",**  
**"authenticationRequirement": "multiFactorAuthentication", "authenticationMethod": "Previously satisfied",**  
**"sessionId": "00406c4a-89b6-fabe-2e75-4d7bdf8fd7c1",**  
**"status": { "errorCode": 0, "failureReason": "Other.", "additionalDetails": "MFA requirement satisfied by claim in the token" }**

Only one session ID was identified as malicious:

| SessionId                            | Authentication Time |
|--------------------------------------|---------------------|
| 00406c4a-89b6-fabe-2e75-4d7bdf8fd7c1 | 2026-05-11 04:53:43 |

As per the input token details related to the sessionId mentioned, the malicious authentication was first performed on **2026-05-11 04:53:43 from IP 104.234.53.4**

#### Malicious IP

For your reference, here are all the IPs used by the malicious session ID.

| IP Address                              | country | count_ |
|-----------------------------------------|---------|--------|
| 3.142.134.110                           | US      | 979    |
| 2a02:4780:75:afb9::1                    | US      | 943    |
| 18.217.233.162                          | US      | 895    |
| 162.252.174.208                         | US      | 79     |
| 104.168.101.5                           | US      | 58     |
| 104.234.53.4                            | US      | 52     |
| 45.132.225.102                          | AU      | 44     |
| 45.92.229.88                            | US      | 28     |
| 2605:6440:300a:5001:4a94:d13c:dbb0:ec9b | US      | 28     |
| 104.232.37.6                            | US      | 24     |

|                |    |    |
|----------------|----|----|
| 104.234.53.6   | US | 20 |
| 45.8.19.72     | US | 19 |
| 45.8.19.205    | US | 18 |
| 63.135.161.90  | US | 18 |
| 45.8.19.237    | US | 16 |
| 104.234.53.229 | US | 15 |
| 45.8.19.86     | US | 15 |
| 45.92.229.92   | US | 14 |
| 45.132.225.166 | AU | 13 |
| 45.8.19.238    | US | 12 |
| 104.234.53.64  | US | 11 |
| 45.130.83.164  | US | 10 |
| 45.8.19.231    | US | 8  |
| 45.8.19.224    | US | 6  |
| 45.132.225.168 | AU | 4  |
| 216.73.161.207 | US | 3  |
| 104.234.53.227 | US | 3  |
| 63.135.161.93  | US | 3  |
| 63.135.161.108 | US | 3  |
| 102.88.112.192 | NG | 2  |
| 45.132.225.175 | AU | 2  |
| 45.132.225.197 | AU | 2  |
| 45.132.225.163 | AU | 2  |
| 63.135.161.94  | US | 2  |
| 45.8.19.214    | US | 2  |
| 45.8.19.97     | US | 2  |
| 216.73.161.225 | US | 2  |
| 45.132.225.171 | AU | 1  |
| 45.132.225.169 | AU | 1  |



|                |    |   |
|----------------|----|---|
| 45.132.225.195 | AU | 1 |
| 45.132.225.193 | AU | 1 |
| 45.132.225.184 | AU | 1 |
| 45.132.225.185 | AU | 1 |
| 45.132.225.202 | AU | 1 |
| 45.132.225.174 | AU | 1 |
| 45.132.225.179 | AU | 1 |
| 45.8.19.210    | US | 1 |
| 45.8.19.209    | US | 1 |
| 45.8.19.220    | US | 1 |
| 45.8.19.216    | US | 1 |
| 45.132.225.56  | AU | 1 |
| 45.132.225.55  | AU | 1 |
| 104.234.53.246 | US | 1 |
| 104.234.53.110 | US | 1 |
| 104.234.53.231 | US | 1 |
| 45.130.83.102  | US | 1 |
| 45.92.229.75   | US | 1 |

**Initial Authentication Details:**

| Field            | Value                                |
|------------------|--------------------------------------|
| Date & Time      | <b>2026-05-11 04:53:43 UTC</b>       |
| User             | erika.jesham@gentingplantations.com  |
| Application      | OfficeHome                           |
| IP Address       | <b>104.234.53.4</b>                  |
| Location         | New York, US                         |
| Client App       | Browser                              |
| Browser          | Chrome 148.0.0                       |
| Operating System | Windows 10                           |
| Sign-in Type     | Interactive                          |
| Status           | Success                              |
| Session ID       | 00406c4a-89b6-fabe-2e75-4d7bdf8fd7c1 |
| Correlation ID   | ec3a7752-038a-4594-b8cd-bd35c794ecb0 |

This event is the **earliest successful authentication** identified from the investigated IP address and serves as the **starting point of the suspicious activity timeline**.

**Key observations:**

- This is the **earliest successful authentication** recorded during the investigation window.
- MFA was required by Conditional Access; however, **no fresh MFA challenge occurred** during this sign-in.
- The sign-in was permitted because **MFA requirements were satisfied by claims already present in the authentication token**.
- The device used for this sign-in was **unmanaged and non-compliant**.

This event represents the **initial confirmed access point** for the session used later in Microsoft 365 workloads.

**Conditional Access and MFA Evaluation:**

For this OfficeHome interactive sign-in, Conditional Access did not actively enforce MFA at that moment. The “MFA enforcement for all user” policy was only in Report-only mode (reportOnlySuccess), and the other MFA-related policies were not applied because the user conditions didn’t match. The sign-in shows “MFA requirement satisfied by claim in the token,” meaning the session token already contained a valid MFA claim from a prior authentication, and Entra accepted that existing claim rather than prompting again.

**Key Observations**

- No interactive MFA prompt was recorded during this authentication.
- MFA was considered satisfied based on **existing token claims**, not a fresh authentication challenge.

This indicates that Azure AD trusted the authentication token presented during the sign-in and did not require a new MFA interaction at that time.

The authentication originated from an unmanaged and unregistered device with no associated device trust or compliance state. Despite this, access was granted because the MFA requirement was already satisfied at the token level.

The sign-in was allowed because no Conditional Access policy actively enforced controls. The applicable MFA policy was in report-only mode, and other policies did not apply due to user scoping. Authentication relied on an existing session token that already contained an MFA claim, so no new MFA challenge was triggered.

## 2- Activities performed by Threat Actor (Start → End)

Following the initial AiTM-driven token theft, the threat actor’s activity can be grouped into several distinct operational phases. After gaining Initial Access through the replayed session token, the attacker typically begins a brief Discovery phase, validating mailbox access, enumerating folders, and identifying high-value communication threads or financial workflows.

Using the **Session ID**, the following activity sequence was observed:

- Access to Microsoft 365 workloads without additional authentication
- Repeated interactions with files and mailbox items
- Access patterns inconsistent with the user’s historical behavior

This section provides a detailed breakdown of the attacker's actions across each Microsoft 365 workload accessed through the compromised session. Because AiTM attacks grant the threat actor a fully authenticated token, their activity appears as legitimate user operations within Exchange Online, SharePoint/OneDrive, Teams, and other workloads.

Below is the list of operations associated with this Session ID: **00406c4a-89b6-fabe-2e75-4d7bdf8fd7c1**

| Operations               | Count |
|--------------------------|-------|
| MailItemsAccessed        | 2,236 |
| Send                     | 256   |
| AddedToSharingLink       | 252   |
| AddedToSecureLink        | 252   |
| UserLoggedIn             | 48    |
| Update                   | 32    |
| SharingSet               | 29    |
| MoveToDeletedItems       | 9     |
| PageViewedExtended       | 7     |
| SharingLinkUpdated       | 6     |
| SecureLinkUpdated        | 6     |
| SoftDelete               | 4     |
| PageViewed               | 4     |
| FilePreviewed            | 3     |
| FileAccessed             | 3     |
| HardDelete               | 2     |
| New-InboxRule            | 2     |
| Create                   | 1     |
| UserLoginFailed          | 1     |
| SignInEvent              | 1     |
| FileUploaded             | 1     |
| ListViewed               | 1     |
| FileDownloaded           | 1     |
| SharingInheritanceBroken | 1     |

|                                  |   |
|----------------------------------|---|
| SharingLinkCreated               | 1 |
| SecureLinkCreated                | 1 |
| UserExpirationChanged            | 1 |
| Remove-InboxRule                 | 1 |
| Set-MailboxCalendarConfiguration | 1 |

### MailItemAccessed

#### Observed Behavior

Extremely high volume of Bind (MailItemAccessed) operations across:

- Inbox
- Sent Items
- Archive
- Hundreds of emails accessed within short time windows → not typical user behavior

### Suspicious Patterns

- Bulk mailbox enumeration
- Access across multiple folders rapidly
- Same session ID repeatedly used (automated activity indicator)
- Activity clustered in **very short bursts**

### Send Operations Analysis

#### Observed Behavior

- Large number of **emails sent**, especially:
  - **"Erika Jesham shared 'Genting Plantations PYMT 09992 Pdf'"**
- 100+ outbound emails sent to **multiple domains (internal + external)**

### Suspicious Patterns

- Mass sending of **identical file/link to large audience**
- High burst frequency within minutes
- Distributed IP usage (4.241.x, 48.210.x etc.)

## Delete Operations Analysis

### Observed Behavior

- Evidence of:
  - **MoveToDeletedItems**
  - **SoftDelete / HardDelete**

### Suspicious Patterns

- Deletion shortly after send/sharing activity
- Activity across multiple IPs

| Subject                                                                                      | ItemFolderPath                  |
|----------------------------------------------------------------------------------------------|---------------------------------|
| Undeliverable: Erika Jesham shared " Vendor Agreement" with you                              | \Archive                        |
| Erika Jesham shared " Vendor Agreement" with you                                             | \Archive                        |
| Undeliverable: Payment Requisition Southern Region RSPO, MSPO, and RSPO NCR Closure 2026     | \Archive                        |
| Undeliverable: Fw: List of Stakeholder                                                       | \Archive                        |
| Undeliverable: Fw: Payment Requisition Southern Region RSPO, MSPO, and RSPO NCR Closure 2026 | \Archive                        |
| Erika Jesham shared " Vendor Agreement" with you                                             | \Deleted Items                  |
| Erika Jesham shared " Vendor Agreement" with you                                             | \Sent Items                     |
| Hi                                                                                           | \Recoverable<br>Items\Deletions |
| Hi                                                                                           | \Deleted Items                  |
| Hi                                                                                           | \Sent Items                     |
| Hi                                                                                           | \Inbox                          |

## File Operations & Sharing Analysis

### Observed Behavior

- Massive activity around file:
  - **"Genting Plantations PYMT 09992 Pdf"**

### Key Actions

- Uploaded → Accessed → Downloaded → Shared
- Shared via:
  - OneDrive SecureLink
  - SharingLink
- Sent to:
  - Multiple external recipients

### Suspicious Indicators

- Bulk sharing in minutes
- External domains involved
- Repeated sharing of same file

### Inbox Rule:

- User: erika.jesham@gentingplantations.com
- Operation: New-InboxRule (Rule successfully created)
- Timestamp: 11 May 2026, 23:46:31 UTC
- Client IP: 45.132.225.186
- Access Method: Outlook Web Access (OWA)
- Workload: Exchange

## Rule Configuration Details

The inbox rule created has the following behavior:

- Rule Name: ..(suspicious naming pattern — minimal/obfuscated)
- Action(s):
  - Move incoming emails to Archive folder
  - Mark emails as Read
  - Stop further rule processing

This rule exhibits multiple characteristics commonly associated with malicious inbox manipulation:

- Email Hiding Behavior
  - Moving emails to Archive + marking as read can conceal incoming messages from the user's primary inbox view
- Rule Processing Termination
  - StopProcessingRules = True ensures no other rules apply afterward
  - This guarantees attacker rule takes precedence and prevents legitimate rules from acting
  - Rule name .. appears non-descriptive , which is often seen in attacker-created rules

## Inbox Rule Removal Activity Summary

- User: erika.jesham@gentingplantations.com
- Operation: Remove-InboxRule (Rule successfully deleted)
- Timestamp: 12 May 2026, 18:54:06 UTC
- Client IP: 104.168.101.5
- Access Method: Outlook Web Access (OWA)
- Workload: Exchange
- Both rule creation and deletion occurred within the same session



Common sequence observed in compromises:

- Create rule → Hide emails → Maintain access → Remove evidence
- Deleting the rule later can indicate:
- Cleanup attempt by attacker

The CSV file name “**2605180030003212 UAL Activity logs**” containing tabs for the relevant UAL event logs is added into the secure file transfer portal.

## 4- Remediation Activities (When it stopped)

This section outlines the remediation actions taken to contain and terminate the attacker’s access following the AiTM-driven compromise. Because the threat actor leveraged a stolen session token, immediate steps were required to revoke active sessions, reset credentials, and remove any persistence mechanisms established during the malicious activity. Remediation typically includes password resets, MFA method validation, forced sign-outs, token invalidation, and cleanup of malicious mailbox rules or unauthorized configuration changes. By correlating these actions with the final malicious session activity, we can clearly determine when the attacker’s access was effectively stopped and confirm that no additional unauthorized operations occurred after remediation was applied.

On 14 May 2026, the impacted account underwent a series of remediation activities, beginning with a self-service password reset at approximately 01:58 UTC, followed by multiple refresh token invalidations to revoke active sessions. At 02:14 UTC, an administrator enforced MFA re-registration by removing existing authentication methods, followed by an additional password reset. Between 02:56 and 02:57 UTC, the user reconfigured authentication methods and completed security setup. Notably, an application password was created at 02:57 UTC, which should be reviewed as part of the investigation. A subsequent password reset attempt at 07:19 UTC failed due to policy restrictions.

➔ Actions to reset the password were performed on **14/05/2026 01:58 UTC UTC**.

# Recommendations

This section provides a set of targeted recommendations designed to strengthen identity security, reduce the risk of similar compromises, and enhance detection capabilities across the environment. These measures address the weaknesses observed during the investigation and outline practical steps customers can implement to harden authentication, mailbox protections, workload configurations, and overall monitoring posture.

## Identity & Access

- Enforce **Conditional Access** with **phish-resistant MFA** (FIDO2/Certificate-based) wherever feasible.
- Enable **continuous access evaluation (CAE)** and **token protection for sign-in sessions** where available.
- Restrict legacy/basic auth (fully disabled), audit and remove unneeded protocols.
- Tighten **MFA registration**—require compliant/Hybrid Azure AD joined devices or trusted locations for MFA changes.
- Enable **sign-in risk** and **user risk** policies (Entra ID Protection), alerting, and auto-remediation thresholds.
- Enforce **number matching** with MFA push notifications and geolocation in prompts.
- Monitor and restrict **OAuth consent**; require admin consent for high-impact permissions; review app consents regularly.

## Monitoring & Detection

- Baseline user sign-in patterns (device, ASN, geo) and alert on **anomalous IPs**, **impossible travel**, and **new MFA registrations**.
- Leverage **Defender for Cloud Apps** (if licensed) for session anomaly detection and OAuth app governance.
- Enable **Safe Links/Safe Attachments** and user-reporting workflows; review **MDO** submissions regularly.

# Appendix

## AiTM (Adversary-in-the-Middle) Quick Explainer

### What is AiTM?

AiTM uses a phishing proxy to intercept credentials and **steal session tokens** post-MFA. Attackers then reuse valid tokens to access accounts without triggering MFA again.

### Indicators commonly seen in AiTM:

- **Single session ID** persisting over time with new IPs or geos.
- Sign-ins show successful MFA but originate from unfamiliar infrastructure.
- Rapid mailbox rule creation, reply-chain hijacking, or app consent prompts shortly after sign-in.
- Lack of password changes but continued access via token reuse.

### Mitigations:

- Phish-resistant MFA (FIDO2/Cert-based), Conditional Access with device state, token binding/protection (where available), and Continuous Access Evaluation.
- Block legacy protocols; limit MFA registration to compliant/trusted contexts.
- Behavioural detection for AiTM URL patterns and known phishing proxy infrastructures.

For additional background on AiTM techniques and Microsoft's guidance for detecting and mitigating these attacks, the following official documentation provides a detailed explanation of attacker methods and recommended defenses.

[Resurgence of a multi-stage AiTM phishing and BEC campaign abusing SharePoint](#) | [Microsoft Security Blog](#)

[Detecting and mitigating a multi-stage AiTM phishing and BEC campaign](#) | [Microsoft Security Blog](#)

[Defeating Adversary-in-the-Middle phishing attacks](#) | [Microsoft Community Hub](#)